GUION MAESTRO DE EXPOSICIÓN – HITO 1

AuditPIMS: Agente de Evidencia y Auditoría

Docente: Edward Vicente Zarate Carlos | Grupo 4: Bernahola, Contreras, Soncco, Velasque, Quispe

ESTRATEGIA 'SHOW ME THE CODE' (Linus Torvalds): Cero diapositivas aburridas. Se proyecta el Informe Técnico en PDF y la terminal de VS Code ejecutando la IA en vivo. Todo el equipo domina este guion para alternar o apoyarse con total naturalidad.

1. INTRODUCCIÓN, PROBLEMA Y MARCO NORMATIVO (0:00 - 1:30 min)

[PANTALLA] QUÉ PROYECTAR EN PANTALLA: Abrir el PDF del Informe Técnico en las páginas 2 y 3.

[DISCURSO] QUÉ DECIR EN LA EXPOSICIÓN:

"Buenos días profesor. Somos el Grupo 4 y nuestro proyecto es AuditPIMS: Agente de Evidencia y Auditoría.

En un Sistema de Gestión de Privacidad de la Información (PIMS), el mayor cuello de botella no es redactar políticas, sino demostrar con evidencias objetivas que los controles se cumplen en el día a día.

Para este Hito 1, nos fundamentamos en dos marcos normativos estrictamente vigentes:
1. La nueva norma ISO/IEC 27701:2025 (2.ª edición, octubre 2025): que ahora es un estándar independiente y certificable por sí mismo sin exigir antes ISO 27001.
2. El marco legal peruano obligatorio: la Ley N.º 29733 y su nuevo Reglamento aprobado mediante el D.S. N.º 016-2024-JUS (vigente desde marzo de 2025), que introduce exigencias como la notificación de brechas en 48 horas y el Oficial de Datos Personales."

2. DE PROMPT A SKILL MODULAR (1:30 - 3:00 min)

[PANTALLA] QUÉ PROYECTAR: Mostrar la estructura de carpetas en VS Code: auditoria-evidencias-pims (SKILL.md, references y assets).

[DISCURSO] QUÉ DECIR EN LA EXPOSICIÓN:

"El primer reto técnico del Hito 1 fue transformar la tarea: pasar de un prompt improvisado a una skill estructurada y reutilizable.

Si un auditor usa un prompt suelto en ChatGPT como 'Revisa esta política y dime si cumple ISO 27701', el modelo comete fallas graves: responde con generalidades, no cita fragmentos probatorios, no distingue si la empresa es Responsable o Encargada, y cada vez usa criterios distintos. No es auditable.

Para solucionarlo, construimos la skill 'auditoria-evidencias-pims', compuesta por:
• SKILL.md: Define el trigger semántico y 3 Modos: M1 (Planificar checklist), M2 (Evaluar con 6 criterios de ISO 19011) y M3 (Consolidar matriz e informe).
• Carpeta references/: Base de conocimiento modular con 52 controles (CL, RT, EN, SG), criterios de evaluación y el resumen de la Ley 29733.
• Carpeta assets/: Plantillas formales de matriz de evidencias e informe de hallazgos."

3. DEMOSTRACION EN VIVO - 'SHOW ME THE CODE' (3:00 - 5:30 min)

[PANTALLA] QUE PROYECTAR: Compartir la Terminal integrada de VS Code ejecutando el script con IA real.

> Caso 1: Deteccion de Falla Legal Critica (Evidencia E6)

```
python3 auditor_con_ia.py --evaluar E6
```

[DISCURSO] QUE EXPLICAR MIENTRAS LA IA RESPONDE:

"Aqui auditamos el Procedimiento de Incidentes (E6). Fijense como la IA evalua los 6 criterios de ISO 19011 citando el texto y detecta la falla legal mas critica:
El procedimiento de la empresa fijaba 72 horas para reportar brechas a la autoridad (copiando el RGPD europeo). La skill detecta inmediatamente que bajo el D.S. 016-2024-JUS de Peru el plazo legal estricto es de 48 horas. Dictamina automaticamente No Conformidad Mayor, cita el requisito, la evidencia y la desviacion, y genera las recomendaciones correctivas."

> Caso 2: Regla de Oro - 'Sin Evidencia no hay Conformidad' (Evidencia E8)

```
python3 auditor_con_ia.py --evaluar E8
```

[DISCURSO] QUE EXPLICAR MIENTRAS LA IA RESPONDE:

"Probamos el control de cifrado en base de datos. Solo se presento una entrevista testimonial donde el Jefe de TI afirma: 'Las bases de datos en PostgreSQL estan totalmente cifradas'.
Un chatbot comun diria 'Conforme'. Nuestra skill aplica la regla de oro: una declaracion verbal aislada carece de evidencia objetiva. Dictamina 'No Verificable' y exige configuraciones tecnicas y reportes reales."

> Caso 3: Consolidacion Automatica de Matriz (Modo M3)

```
python3 probar_auditor.py --consolidar
```

[DISCURSO] QUE EXPLICAR:

"En el Modo M3, la skill consolida las 8 evidencias evaluadas, genera la matriz con simbologia ISO (cumple, parcial, no cumple), calcula el porcentaje de conformidad y genera el plan de accion ordenado por severidad (30, 60 y 90 dias)."

4. CONCLUSIONES Y SALTO AL HITO 2 (5:30 - 6:30 min)

[DISCURSO] QUE DECIR EN EL CIERRE:

"En las pruebas alcanzamos un 87.5% de coincidencia con la clave de auditoria. La unica discrepancia en la evidencia E3 demostro que la skill fue incluso mas estricta que la clave, detectando vacios en plazos numericos.

¿Que representa el Hito 1? Un Skill y un Asistente funcional que asiste al auditor humano.
¿Que haremos en el Hito 2 (Proyecto Agentico)? Darle autonomia completa. Conectaremos herramientas MCP (Model Context Protocol) para que el agente inspeccione carpetas y bases de datos automaticamente, calcule hashes SHA-256 de integridad documental y audite de forma continua el PIMS.

Muchas gracias, quedamos atentos a sus preguntas."

5. BANCO DE PREGUNTAS TRAMPA DEL DOCENTE Y RESPUESTAS BLINDADAS

[?] ¿Por que crearon codigos propios como CL-04, RT-02, SG-04 y no los de la norma ISO oficial?

[RESPUESTA]: Por dos motivos: primero, el texto integro de ISO/IEC 27701:2025 esta protegido por derechos de autor de ISO, por lo que creamos resumenes propios. Segundo, organizamos funcionalmente los roles: CL para Clausulas del sistema, RT para Responsables, EN para Encargados y SG para Seguridad compartida. Indicamos expresamente que son referenciales.

[?] ¿Por que una Skill y no un simple prompt largo en ChatGPT?

[RESPUESTA]: Una Skill es arquitectura de software: tiene un archivo de metadatos (SKILL.md) con activacion semantica automatica, separacion modular de conocimiento en references/ (evita saturar la memoria de contexto), plantillas inmutables y reglas estrictas de no invencion.

[?] ¿Por que en la evidencia E3 el asistente dio 'No conformidad menor' si su clave decia 'Conforme'?

[RESPUESTA]: Demostro el rigor del sistema. El documento de prueba PRO-ARCO-01 decia que responderia 'conforme a los plazos del reglamento', pero no ponia los dias habiles en numeros. Nuestro asistente aplico con rigor los criterios de Suficiencia y Completitud: sin plazos cuantificables no se puede auditar el servicio. La discrepancia fue un aporte de rigor valido.

[?] ¿Que le falta a este Hito 1 para ser verdaderamente un Agente (Hito 2)?

[RESPUESTA]: Le falta autonomia de ejecucion y herramientas externas (MCP). En el Hito 1 requiere que un humano le entregue el documento. En el Hito 2 tendra un bucle continuo: inspeccionara carpetas o bases de datos por si solo, calculara hashes SHA-256 de integridad para cumplir con el control A.3.14 y emitira alertas continuas.

[?] ¿Como evitan que la IA alucine o invente cumplimientos?

[RESPUESTA]: Con las 7 Reglas Obligatorias: (1) Sin evidencia no hay conformidad, (2) Citar siempre textualmente la evidencia, (3) No inventar datos inexistentes, y (4) La decision final siempre recae en el auditor humano.

6. TABLA RESUMEN DEL BANCO DE EVIDENCIAS (E1 a E8)

ID	Evidencia	Control	Falla Sembrada	Dictamen
E1	Política de Privacidad v1.0	CL-04	Aprobada en 2021; cita D.S. 003 derogado;	No conformidad menor
E2	Registro Consentimientos CRM	RT-02	4 de 12 sin fecha ni canal; datos sin anon	No conformidad mayor
E3	Procedimiento Derechos ARCO	RT-07	Sin plazos numéricos explícitos ni registr	NC menor (Rigor IA)
E4	Acta de Capacitación PIMS	CL-09	Asistencia 96% pero sin evaluar efectivida	Oportunidad de mejora
E5	Contrato Proveedor Call Center	RT-15	Sin cláusulas DPA ni de seguridad; firmas	No conformidad mayor
E6	Procedimiento de Incidentes	SG-04	Borrador; fija 72h frente a 48h del D.S. 0	No conformidad mayor
E7	Inventario Tratamientos RoPA	CL-12	Lista 5 de 8 procesos; 2 sin base legal	No conformidad menor
E8	Entrevista al Jefe de TI	SG-02	Declaración verbal sin soporte técnico alg	No verificable